

Runtime Policy Enforcement at the AI Agent-to-Tool Boundary

github.com/poojakira/mcp-agent-security-gateway - public, default branch main

EVIDENCE POSTURE

Verified, scoped, reproducible

Claims are constrained to the repository evidence snapshot and stated limitations.

718

Tests passed

0

Tests failed

82.46%

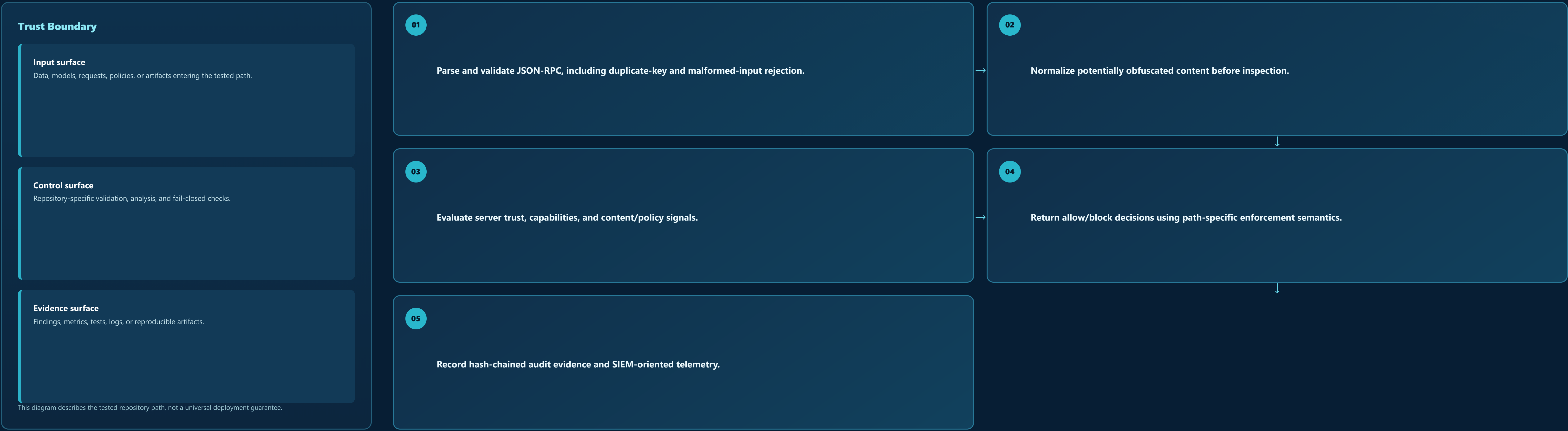
Statement coverage

55

Prompt-injection collection entries

SYSTEM VIEW

Architecture and Threat-Control Flow



Research Contribution

An application-layer inspection and authorization point for agent-generated MCP tools/call requests that combines JSON-RPC validation, normalization, trust/capability checks, heuristic content detection, policy evaluation, and tamper-evident audit telemetry before downstream tool execution.

Verified Evidence

EV-01 718 tests passed, 0 failed.	EV-02 82.46% statement coverage - 5,524 statements, 969 missed.
EV-03 The Python 3.10 and 3.11 test jobs also completed successfully.	EV-04 Ruff/format, Pyright, Bandit, pip-audit, CodeQL, Windows control-plane validation, container build, Trivy/Grype/SBOM jobs completed successfully.
EV-05 55 entries remain in the named prompt-injection pattern collection.	EV-06 Elastic rule records: 9

Method and Control Path

01	Parse and validate JSON-RPC, including duplicate-key and malformed-input rejection.
02	Normalize potentially obfuscated content before inspection.
03	Evaluate server trust, capabilities, and content/policy signals.
04	Return allow/block decisions using path-specific enforcement semantics.
05	Record hash-chained audit evidence and SIEM-oriented telemetry.

Limitations and Residual Risk

- No external population-level false-positive/false-negative rate is established.
- Synthetic correlation fixtures and local microbenchmarks are not production efficacy or SLO evidence.
- Enforcement semantics are not identical across every integration path.
- Only traffic routed through the gateway can be inspected or blocked.
- A successful CI suite is not evidence of a live production SOC deployment.

Reproducibility

Expected at the cited snapshot: 718 passed, 82.46% statement coverage.

Evidence Provenance

Claim discipline Metrics come from the repository's verified metrics and research brief.
Scope discipline Benchmarks are reported only at their documented fixture, dataset, or test scope.
Reproduction PDF and PNG are generated locally from committed evidence without paid services.